

Seguretat física 3.0

Amenaces

Les amenaces són esdeveniments externs que poden causar danys al sistema informàtic. A diferència de les vulnerabilitats, que són factors interns, les amenaces representen accions malicioses que poden provocar danys. Així, una amenaça pot explotar una determinada vulnerabilitat per causar dany al sistema.

Tenim dos tipus d'amenaces principals:

- **Amenaces físiques**: Temperatura, humitat, pols, descarregues electrostàtiques, etc.
- **Amenaces logiques**: Virus, troians, cucs, malware, exploits, spyware, etc.

Anàlisi forense en sistemes informàtics

Es podria definir l'**anàlisi forense** informàtica com el procés d'aplicar el mètode científic als sistemes informàtics amb la finalitat d'identificar, recollir, adquirir, preservar i analitzar l'evidència digital, de manera que sigui acceptada en un procés judicial.

Les 6 Preguntes Clau de la Investigació (Línia Policíaca):

- **Què s'ha comès?** (Ex: intrusió, fugida de dades, amenaces).
- **Quan ha passat?** (Cronologia dels fets).
- **On s'ha comès?** (Ordinador local, servidor remot, dispositiu mòbil, servei al núvol com Dropbox/OneDrive).
- **Qui ho ha comès?** (Atribució de l'autor/usuari).
- **Com s'ha dut a terme?** (Vectors d'atac, exploits, SQL Injection, XSS, etc.).
- **Per què s'ha comès?** (Motivació o context).

Assegurament de l'evidència digital

La fase d'assegurament permet protegir l'escena de l'incident, de manera similar a l'escena d'un crim, garantint que les proves no es contaminin ni s'alterin.
Pasos clau per a la protecció de l'escena:

- Perímetre de seguretat: Identificar la zona, limitar l'accés a persones i desconnectar xarxes (cable, Wi-Fi i Bluetooth).
- Documentació visual: Fotografiar o enregistrar en vídeo l'estat dels equips, el cablejat i la topografia de la xarxa.
- Control temporal: Anotar, fotografiar o filmar la data i hora del sistema abans de qualsevol manipulació.
- Etiquetat exhaustiu: Identificar i etiquetar tots els cables i dispositius necessaris per al posterior anàlisi.
- Gestió d'equips apagats: Desconnectar el corrent posterior i extreure la bateria en portàtils per evitar l'autoencesa.

Gestió d'equips encesos: Desendollar de cop, excepte si cal extreure la memòria RAM o hi ha dades visibles / esborrament actiu.

Identificació i adquisició de proves

El procés d'adquisició de l'evidència busca extreure la informació digital mitjançant tècniques de clonació exacte que mantinguin la integritat de la prova.
Fonaments del procés de clonació i font de dades:

- Fonts d'evidència: Discs durs, SSD, memòries USB, dispositius mòbils, càmeres de seguretat, impressores o servidors Cloud.
- Còpia Bit a Bit (Imatge Forense): Es treballa sobre una còpia exacta del suport original, incloent particions ocultes i espai no assignat.
- Garantia d'integritat (Hash): Es calcula un valor hash (ex: SHA-256) a l'origen i a la destí per comprovar que la còpia sigui 100% idèntica.
- Eines de clonació: Ús de duplicadors per maquinari (write blockers) o eines de programari especialitzat (dd, FTK Imager).
- Neteja del suport de destí: El disc on es realitza la còpia ha de ser nou o haver estat esborrat de forma segura (wipe).

Anàlisi forense i informe pericial

L'anàlisi forense i la cadena de custòdia permeten estudiar les dades extretes i presentar les conclusions davant d'un tribunal o l'empresa.
Aspectes clau de l'anàlisi i presentació:

- Cadena de custòdia: Documentació ininterrompuda de qui té, gestiona i emmagatzema les evidències en tot moment.
- Categories de dades: Anàlisi de fitxers accessibles, fitxers esborrats recuperables i Ambient Data (com el file slack).
- Eines d'anàlisi: Ús de programari especialitzat comercial (EnCase, FTK) o de codi obert (Autopsy, The Sleuth Kit, Volatility).
- Llenguatge de l'informe: Redacció clara, concisa i accessible per a persones sense coneixements tècnics (jutges, advocats o directius).
- Ratificació judicial: Defensa rigorosa de les metodologies utilitzades i les conclusions obtingudes.